

CIFP César Manrique.

Ciberseguridad en Entornos de las Tencologías de la Información.

Módulo: Incidentes de Ciberseguridad (IHC)

Profesor: Luis Martínez Ibáñez

ANÁLISIS Y PROTECCIÓN DE ACTIVOS DE INFORMACIÓN

Juan Carlos Francisco Mesa



Esta obra está licenciada bajo la Licencia Creative Commons Atribución 4.0 Internacional. Para ver una copia de esta licencia, visite <http://creativecommons.org/licenses/by/4.0/> o envíe una carta a Creative Commons, PO Box 1866, Mountain View, CA 94042, USA.

Índice

CONTEXTO DEL CASO PRÁCTICO.....	1
Empresa: "TechSolutions Canarias S.L."	1
FASE 1: INVENTARIO Y CLASIFICACIÓN DE ACTIVOS.....	2
Tarea 1.1: Identificación de Activos.....	2
INVENTARIO DE ACTIVOS DE INFORMACIÓN.....	2
TABLA DE INVENTARIO.....	2
Tarea 1.2: CLASIFICACIÓN DE ACTIVOS SEGÚN CIA.....	5
MATRIZ DE CLASIFICACIÓN CIA.....	5
Tarea 1.3: Identificación de Vulnerabilidades.....	7
ANÁLISIS DE VULNERABILIDADES.....	7
FICHA DE ANÁLISIS DE VULNERABILIDADES.....	7
MATRIZ DE RIESGOS RESUMIDA.....	11
FASE 2: MEDIDAS DE SEGURIDAD FÍSICA (Individual-1h).....	12
Tarea 2.1: Análisis del Perímetro Físico.....	12
ANÁLISIS DE SEGURIDAD FÍSICA.....	12
EVALUACIÓN DE SEGURIDAD FÍSICA ACTUAL.....	12
Tarea 2.2: Plan de Seguridad Física.....	15
PLAN DE SEGURIDAD FÍSICA.....	15
1. MEDIDAS PERIMETRALES.....	15
2. PROTECCIÓN SALA DE SERVIDORES.....	17
3. POLÍTICA DE ESCRITORIO LIMPIO Y GESTIÓN DE SOPORTES.....	18

4. PRESUPUESTO CONSOLIDADO.....	19
FASE 3: MEDIDAS DE SEGURIDAD LÓGICA.....	20
Tarea 3.1: Hardening de Sistemas.....	20
HARDENING DE SISTEMAS.....	20
A) ESTACIONES DE TRABAJO WINDOWS (Windows 10/11).....	20
B) SERVIDORES LINUX.....	21
B.1 Nivel Sistema Operativo.....	21
B.2 Nivel Servicios.....	21
B.3 Nivel Red.....	22
B.4 Nivel Usuarios y Permisos.....	23
C) DISPOSITIVOS DE RED (Switches, Routers, WiFi).....	23
Segmentación de Red Propuesta (Esquema VLANs).....	24
Tarea 3.2: Gestión de Accesos e Identidades.....	25
GESTIÓN DE ACCESOS E IDENTIDADES.....	25
1. POLÍTICA DE CONTRASEÑAS.....	25
2. AUTENTICACIÓN MULTIFACTOR (MFA).....	26
3. GESTIÓN DE USUARIOS.....	27
4. CONTROL DE ACCESO BASADO EN ROLES (RBAC).....	29
Resumen general:.....	31
Tarea 3.3: Protección de Endpoints y Datos.....	32
PROTECCIÓN DE ENDPOINTS Y DATOS.....	32
1. ANTIVIRUS / EDR.....	32
2. DATA LOSS PREVENTION (DLP).....	33

3. COPIAS DE SEGURIDAD.....	35
4. CIFRADO.....	37
Tarea 3.4: Monitorización y Gestión de Vulnerabilidades.....	38
MONITORIZACIÓN Y GESTIÓN DE VULNERABILIDADES.....	38
1. SIEM / MONITORIZACIÓN.....	38
2. GESTIÓN DE VULNERABILIDADES.....	40
2.2 Escaneo de Vulnerabilidades.....	41
3. RESPUESTA A INCIDENTES.....	42

CONTEXTO DEL CASO PRÁCTICO

Empresa: "TechSolutions Canarias S.L."

Sector: Desarrollo de aplicaciones web y móviles.

Ubicación: Oficina en Santa Cruz de Tenerife (150 m²)

Plantilla: 15 empleados, distribuidos de la siguiente manera:

- 8 desarrolladores
- 2 diseñadores
- 3 comerciales
- 1 administrador de sistemas
- 1 gerente

Infraestructura básica:

- 1 sala de servidores (20 m²)
- 2 salas de desarrollo (open space)
- 1 sala de reuniones
- Conexión a Internet de 500 Mbps
- Red local con switches y puntos de acceso WiFi
- 20 equipos de sobremesa
- 10 portátiles
- 3 servidores físicos (web, base de datos, backups)
- Almacenamiento NAS de 8 TB

Situación actual:

La empresa ha crecido rápidamente en los últimos 2 años. Actualmente no tienen un inventario formal de sus activos ni medidas de seguridad documentadas. El gerente te ha contratado como Juan Carlos Francisco Mesa para ayudarles a mejorar su postura de seguridad.

FASE 1: INVENTARIO Y CLASIFICACIÓN DE ACTIVOS

Tarea 1.1: Identificación de Activos

Elabora un inventario completo de los activos de información de TechSolutions Canarias. Debes identificar AL MENOS:

- 5 activos de datos/información (bases de datos, código fuente, documentación, etc.)
- 8 activos de hardware (servidores, equipos, dispositivos de red, etc.)
- 6 activos de software (sistemas operativos, aplicaciones, herramientas, etc.)
- 4 activos de servicios TI (servicios de red, backup, correo, etc.)
- 3 activos humanos (roles con acceso crítico)

INVENTARIO DE ACTIVOS DE INFORMACIÓN

Empresa: TechSolutions Canarias S.L.

Fecha: 16/10/2025

Responsable: Juan Carlos Francisco Mesa

TABLA DE INVENTARIO

ID	Tipo de Activo	Nombre / Descripción	Ubicación	Propietario	Valor de Negocio	Observaciones
DA-001	Datos	Código fuente de aplicaciones web y móviles	Servidor de desarrollo / repositorio GitLab	Gerente / Desarrolladores senior	Alto	Información crítica para el negocio y propiedad intelectual.
DA-002	Datos	Base de datos de clientes y proyectos	Servidor de base de datos (sala de servidores)	Administrador de sistemas	Alto	Contiene información confidencial de clientes.
DA-003	Datos	Documentación técnica y manuales internos	NAS / Google Drive	Administrador de sistemas	Medio	Soporte interno para el desarrollo y mantenimiento.
DA-004	Datos	Datos financieros y administrativos	Equipo del gerente / software contable	Gerente	Alto	Datos sensibles (facturación, nóminas, contratos).
DA-005	Datos	Copias de seguridad (backups)	Servidor de backups / disco externo cifrado	Administrador de sistemas	Alto	Críticas para recuperación ante desastres.

ANÁLISIS Y PROTECCIÓN DE ACTIVOS DE INFORMACIÓN

CETI

ID	Tipo de Activo	Nombre / Descripción	Ubicación	Propietario	Valor de Negocio	Observaciones
HW-001	Hardware	Servidor web	Sala de servidores	Administrador de sistemas	Alto	Alojamiento de aplicaciones en producción.
HW-002	Hardware	Servidor de base de datos	Sala de servidores	Administrador de sistemas	Alto	Procesa y almacena datos de clientes.
HW-003	Hardware	Servidor de backups	Sala de servidores	Administrador de sistemas	Medio	Recurso para copias automáticas de seguridad.
HW-004	Hardware	Almacenamiento NAS (8 TB)	Sala de servidores	Administrador de sistemas	Medio	Repositorio compartido interno.
HW-005	Hardware	Equipos de sobremesa (20 unidades)	Salas de desarrollo	Gerente / Usuarios finales	Medio	Estaciones de trabajo del personal.
HW-006	Hardware	Portátiles (10 unidades)	Oficinas / movilidad	Gerente / Comerciales	Medio	Uso remoto, riesgo por desplazamiento.
HW-007	Hardware	Switches de red (2)	Sala de servidores / rack principal	Administrador de sistemas	Alto	Elemento central de la red interna.
HW-008	Hardware	Puntos de acceso WiFi (3)	Oficinas / áreas comunes	Administrador de sistemas	Medio	Acceso inalámbrico al entorno de trabajo.
SW-001	Software	Sistema operativo Windows 11 Pro	Equipos de sobremesa y portátiles	Administrador de sistemas	Medio	Sistema base para usuarios administrativos.
SW-002	Software	Ubuntu Server / Debian	Servidores físicos	Administrador de sistemas	Alto	Sistema operativo crítico para servidores.
SW-003	Software	Visual Studio Code / JetBrains IDEs	Equipos de desarrolladores	Desarrolladores	Medio	Herramientas principales de desarrollo.
SW-004	Software	GitLab / GitHub Enterprise	Nube / servidor interno	Administrador de sistemas	Alto	Control de versiones y repositorios de código.
SW-005	Software	Suite ofimática (Microsoft 365 / Google Workspace)	Nube / accesos web	Gerente / Todos los empleados	Medio	Comunicación y colaboración interna.
SW-006	Software	Software contable (Contasol / Sage)	Equipo del gerente / nube	Gerente	Alto	Información sensible de finanzas y RRHH.
SV-001	Servicios TI	Correo electrónico corporativo	Nube (Microsoft 365 / Google Workspace)	Administrador de sistemas	Alto	Comunicación principal interna y externa.

ANÁLISIS Y PROTECCIÓN DE ACTIVOS DE INFORMACIÓN

CETI

ID	Tipo de Activo	Nombre / Descripción	Ubicación	Propietario	Valor de Negocio	Observaciones
SV-002	Servicios TI	Servicio de backup automatizado	Servidor local / nube	Administrador de sistemas	Alto	Vital para recuperación ante incidentes.
SV-003	Servicios TI	Hosting web de clientes	Servidor web / proveedor externo	Administrador de sistemas	Alto	Servicio directo al cliente; afecta reputación.
SV-004	Servicios TI	Red corporativa (LAN / WiFi / Firewall)	Oficina / sala de servidores	Administrador de sistemas	Alto	Soporte esencial para toda la infraestructura.
HU-001	Humano	Administrador de sistemas	Oficina / remoto	Gerente	Alto	Control total sobre sistemas críticos.
HU-002	Humano	Gerente general	Oficina dirección	Propietario de la empresa	Alto	Toma decisiones estratégicas y financieras.
HU-003	Humano	Desarrolladores senior	Sala de desarrollo	Gerente	Alto	Acceso directo al código y entornos de despliegue.

Tarea 1.2: CLASIFICACIÓN DE ACTIVOS SEGÚN CIA

Empresa: TechSolutions Canarias S.L.

Fecha: 16/10/2025

MATRIZ DE CLASIFICACIÓN CIA

ID Activo	Nombre del Activo	C	I	D	Justificación	Clasificación Global
DA-001	Código fuente de aplicaciones	ALTO	ALTO	MEDIO	Contiene propiedad intelectual y lógica de negocio esencial; pérdida o filtración afectaría la competitividad.	CRÍTICO
DA-002	Base de datos de clientes y proyectos	ALTO	ALTO	MEDIO	Contiene datos personales protegidos por RGPD y datos comerciales sensibles.	CRÍTICO
DA-003	Documentación técnica y manuales internos	MEDIO	MEDIO	MEDIO	Información interna de soporte, importante pero recuperable.	IMPORTANTE
DA-004	Datos financieros y administrativos	ALTO	ALTO	MEDIO	Incluye información económica, nóminas y contratos; su exposición sería grave.	CRÍTICO
DA-005	Copias de seguridad (backups)	ALTO	ALTO	ALTO	Esencial para recuperación ante incidentes; pérdida implica riesgo de continuidad.	CRÍTICO
HW-001	Servidor web	MEDIO	ALTO	ALTO	Infraestructura esencial para servicios en línea; requiere alta disponibilidad.	CRÍTICO
HW-002	Servidor de base de datos	ALTO	ALTO	ALTO	Almacena datos críticos de clientes y operaciones; indisponibilidad paraliza servicios.	CRÍTICO
HW-003	Servidor de backups	ALTO	ALTO	MEDIO	Almacena copias de seguridad; pérdida afecta recuperación de sistemas.	CRÍTICO
HW-004	Almacenamiento NAS (8 TB)	MEDIO	MEDIO	MEDIO	Contiene documentación interna y recursos de desarrollo.	IMPORTANTE
HW-005	Equipos de sobremesa (20)	MEDIO	MEDIO	MEDIO	Uso operativo diario; fallo puede afectar productividad pero no la continuidad general.	IMPORTANTE
HW-006	Portátiles (10)	ALTO	MEDIO	MEDIO	Riesgo alto por movilidad; posibles fugas de datos si no se cifran.	IMPORTANTE
HW-007	Switches de red (2)	MEDIO	ALTO	ALTO	Elemento central de red local; su fallo corta la conectividad total.	CRÍTICO
HW-008	Puntos de acceso WiFi (3)	MEDIO	MEDIO	MEDIO	Soporte a la conectividad inalámbrica; impacto moderado si falla temporalmente.	IMPORTANTE
SW-001	Sistema operativo Windows 11 Pro	MEDIO	MEDIO	MEDIO	Base para equipos de oficina; su fallo afecta usuarios, no operaciones críticas.	IMPORTANTE

ANÁLISIS Y PROTECCIÓN DE ACTIVOS DE INFORMACIÓN

CETI

ID Activo	Nombre del Activo	C	I	D	Justificación	Clasificación Global
SW-002	Ubuntu Server / Debian	ALTO	ALTO	ALTO	Sistema base de servidores críticos; su compromiso impacta toda la infraestructura.	CRÍTICO
SW-003	IDEs de desarrollo (VS Code / JetBrains)	MEDIO	MEDIO	MEDIO	Herramientas esenciales, pero reemplazables rápidamente.	NORMAL
SW-004	GitLab / GitHub Enterprise	ALTO	ALTO	ALTO	Control del código fuente y versiones; pérdida o alteración afectaría la producción.	CRÍTICO
SW-005	Suite ofimática (M365 / Google Workspace)	MEDIO	MEDIO	MEDIO	Comunicación y colaboración; interrupción temporalmente gestionable.	IMPORTANTE
SW-006	Software contable (Contasol / Sage)	ALTO	ALTO	MEDIO	Maneja datos económicos y fiscales; exposición o corrupción grave.	CRÍTICO
SV-001	Correo electrónico corporativo	ALTO	MEDIO	ALTO	Medio principal de comunicación; contiene información confidencial.	CRÍTICO
SV-002	Servicio de backup automatizado	ALTO	ALTO	ALTO	Garantiza continuidad del negocio; pérdida implica riesgo total.	CRÍTICO
SV-003	Hosting web de clientes	ALTO	ALTO	ALTO	Servicio comercial visible al cliente; afecta reputación y contratos.	CRÍTICO
SV-004	Red corporativa (LAN / WiFi / Firewall)	ALTO	ALTO	ALTO	Soporte de toda la infraestructura tecnológica; indisponibilidad paraliza la empresa.	CRÍTICO
HU-001	Administrador de sistemas	ALTO	ALTO	ALTO	Acceso total a servidores, redes y datos; error o acción maliciosa sería devastadora.	CRÍTICO
HU-002	Gerente general	ALTO	ALTO	MEDIO	Responsable de decisiones estratégicas y financieras.	CRÍTICO
HU-003	Desarrolladores senior	ALTO	ALTO	MEDIO	Acceso a código fuente y entornos de producción.	CRÍTICO

Escala de valoración:

- ALTO (3) → Impacto crítico
- MEDIO (2) → Impacto significativo
- BAJO (1) → Impacto menor

Clasificación global del activo:

- CRÍTICO: Suma ≥ 8 puntos o cualquier dimensión en ALTO
- IMPORTANTE: Suma 5–7 puntos
- NORMAL: Suma ≤ 4 puntos

Tarea 1.3: Identificación de Vulnerabilidades

Selecciona 5 activos críticos de tu inventario e identifica:

- Al menos 2 vulnerabilidades potenciales para cada uno
- Las amenazas que podrían explotar esas vulnerabilidades
- El riesgo resultante (bajo/medio/alto)

ANÁLISIS DE VULNERABILIDADES

Empresa: TechSolutions Canarias S.L.

Fecha: 16/10/2025

Analista: Juan Carlos Francisco Mesa

FICHA DE ANÁLISIS DE VULNERABILIDADES

ACTIVO #1: Base de datos de clientes y proyectos

Clasificación: C: ALTO | I: ALTO | D: MEDIO

Ubicación: Servidor de base de datos (sala de servidores)

Responsable: Administrador de sistemas

- **VULNERABILIDAD 1**
 - **Descripción:** Falta de cifrado en reposo o en tránsito de los datos almacenados.
 - **Amenaza:** Robo o interceptación de información confidencial (datos personales, contratos).
 - **Vector de ataque:** Acceso no autorizado a través de la red o robo de disco duro del servidor.
 - **Probabilidad:** Media
 - **Impacto:** Alto
 - **Riesgo resultante:** Alto

- **Recomendación:** Implementar cifrado AES en disco y TLS en las conexiones; políticas de acceso restringido.

- **VULNERABILIDAD 2**

- **Descripción:** Acceso con contraseñas débiles o compartidas entre empleados.
- **Amenaza:** Acceso indebido, modificación o eliminación de registros.
- **Vector de ataque:** Ataques de fuerza bruta o abuso de credenciales internas.
- **Probabilidad:** Alta
- **Impacto:** Alto
- **Riesgo resultante:** Alto
- **Recomendación:** Aplicar autenticación multifactor (MFA) y políticas de contraseñas seguras y rotación periódica.

ACTIVO #2: Servidor web

Clasificación: C: MEDIO | I: ALTO | D: ALTO

Ubicación: Sala de servidores

Responsable: Administrador de sistemas

- **VULNERABILIDAD 1**

- **Descripción:** Sistema operativo o framework sin actualizaciones de seguridad recientes.
- **Amenaza:** Explotación de vulnerabilidades conocidas (RCE, inyección, DoS).
- **Vector de ataque:** Ataques a través de internet o servicios expuestos (HTTP/HTTPS).
- **Probabilidad:** Alta
- **Impacto:** Alto
- **Riesgo resultante:** Alto
- **Recomendación:** Establecer políticas de parcheo y actualizaciones periódicas automatizadas.

- **VULNERABILIDAD 2**

- **Descripción:** Configuración insegura del servidor web (puertos abiertos, permisos excesivos).
- **Amenaza:** Escalamiento de privilegios, acceso no autorizado a archivos internos.
- **Vector de ataque:** Exploración de servicios mediante escáneres de red.
- **Probabilidad:** Media
- **Impacto:** Alto
- **Riesgo resultante:** Alto

- **Recomendación:** Aplicar endurecimiento (hardening) del sistema: cerrar puertos innecesarios, usar firewall y revisiones de configuración.

ACTIVO #3: Copias de seguridad (backups)

Clasificación: C: ALTO | I: ALTO | D: ALTO

Ubicación: Servidor de backups / disco externo cifrado

Responsable: Administrador de sistemas

- **VULNERABILIDAD 1**

- **Descripción:** Copias almacenadas sin cifrado o sin control de acceso físico.
- **Amenaza:** Robo o acceso no autorizado a datos sensibles respaldados.
- **Vector de ataque:** Robo físico de dispositivos o acceso remoto sin protección.
- **Probabilidad:** Media
- **Impacto:** Alto
- **Riesgo resultante:** Alto
- **Recomendación:** Cifrar todas las copias y restringir acceso físico y lógico mediante autenticación.

- **VULNERABILIDAD 2**

- **Descripción:** Falta de verificación o pruebas de restauración de backups.
- **Amenaza:** Fallo de recuperación ante desastres o pérdida de información crítica.
- **Vector de ataque:** Error humano o corrupción de archivos.
- **Probabilidad:** Media
- **Impacto:** Alto
- **Riesgo resultante:** Alto
- **Recomendación:** Realizar pruebas de restauración periódicas y automatizar la verificación de integridad.

ACTIVO #4: GitLab / GitHub Enterprise (repositorios de código)

Clasificación: C: ALTO | I: ALTO | D: ALTO

Ubicación: Nube / servidor interno

Responsable: Administrador de sistemas / Desarrolladores senior

- **VULNERABILIDAD 1**

- **Descripción:** Repositorios públicos o mal configurados con código sensible.

- **Amenaza:** Fuga de propiedad intelectual o datos de acceso en el código.
- **Vector de ataque:** Acceso externo a repositorios o indexación por motores de búsqueda.
- **Probabilidad:** Media
- **Impacto:** Alto
- **Riesgo resultante:** Alto
- **Recomendación:** Revisar visibilidad de repositorios, usar .gitignore y auditorías de contenido.

- **VULNERABILIDAD 2**

- **Descripción:** Falta de control de acceso por roles (todos los usuarios con permisos de escritura).
- **Amenaza:** Modificación no autorizada o introducción de código malicioso.
- **Vector de ataque:** Acceso interno indebido o cuenta comprometida.
- **Probabilidad:** Media
- **Impacto:** Alto
- **Riesgo resultante:** Alto
- **Recomendación:** Implementar control de permisos basado en roles y revisión de commits mediante pull requests.

ACTIVO #5: Servicio de correo electrónico corporativo

Clasificación: C: ALTO | I: MEDIO | D: ALTO

Ubicación: Nube (Microsoft 365 / Google Workspace)

Responsable: Administrador de sistemas

- **VULNERABILIDAD 1**

- **Descripción:** Ausencia de autenticación multifactor (MFA) en cuentas de correo.
- **Amenaza:** Compromiso de cuentas por phishing o robo de credenciales.
- **Vector de ataque:** Campañas de phishing o ataques de ingeniería social.
- **Probabilidad:** Alta
- **Impacto:** Alto
- **Riesgo resultante:** Alto
- **Recomendación:** Activar MFA obligatorio y capacitar al personal en reconocimiento de phishing.

- **VULNERABILIDAD 2**

- **Descripción:** Falta de filtros antimalware y antispam avanzados.

- **Amenaza:** Infección por ransomware o fuga de datos mediante archivos adjuntos.
- **Vector de ataque:** Correo electrónico con archivos maliciosos.
- **Probabilidad:** Media
- **Impacto:** Alto
- **Riesgo resultante:** Alto
- **Recomendación:** Implementar filtros de seguridad avanzados, sandboxing y políticas de adjuntos.

MATRIZ DE RIESGOS RESUMIDA

Activo	Vulnerabilidad	Probabilidad	Impacto	Riesgo	Prioridad
BBDD Clientes y Proyectos	Cifrado insuficiente	Media	Alto	Alto	Alta
BBDD Clientes y Proyectos	Contraseñas débiles	Alta	Alto	Alto	Alta
Servidor Web	Falta de actualizaciones	Alta	Alto	Alto	Alta
Servidor Web	Configuración insegura	Media	Alto	Alto	Alta
Backups	Sin cifrado / control físico	Media	Alto	Alto	Alta
Backups	Sin pruebas de restauración	Media	Alto	Alto	Media
GitLab / GitHub	Repositorios públicos	Media	Alto	Alto	Alta
GitLab / GitHub	Permisos excesivos	Media	Alto	Alto	Alta
Correo corporativo	Sin MFA	Alta	Alto	Alto	Alta
Correo corporativo	Sin filtros antimalware	Media	Alto	Alto	Media

FASE 2: MEDIDAS DE SEGURIDAD FÍSICA (Individual-1h)

Tarea 2.1: Análisis del Perímetro Físico

Evalúa la seguridad física actual de TechSolutions y propón mejoras:

ANÁLISIS DE SEGURIDAD FÍSICA

Empresa: TechSolutions Canarias S.L.

Fecha: 16/10/2025

Auditor: Juan Carlos Francisco Mesa

EVALUACIÓN DE SEGURIDAD FÍSICA ACTUAL

Elemento de Seguridad Física	Estado Actual	Problemas Detectados	Medidas Propuestas	Coste Estimado (€)	Prioridad
PERÍMETRO					
Control de acceso al edificio	Cerradura estándar con llaves físicas	Falta de control de entradas/salidas, posible duplicado de llaves	Instalar control electrónico (tarjetas o código PIN) con registro de acceso	1500	Alta
Videovigilancia exterior	No disponible	Sin monitoreo del perímetro ni grabaciones de seguridad	Instalar cámaras IP con grabación 24/7 y almacenamiento en NAS	2000	Alta
Iluminación perimetral	Parcial, solo en acceso principal	Zonas laterales y traseras con poca visibilidad nocturna	Añadir focos LED con sensores de movimiento	800	Media
Vallas / Muros	Paredes de oficina compartidas	No existe separación física reforzada ni señalización	Instalar puerta reforzada de seguridad en acceso principal	1200	Media
SALA DE SERVIDORES					
Control de acceso a sala	Llave física común	Personal no autorizado podría acceder	Reemplazar por cerradura electrónica o biométrica	1000	Alta

Elemento de Seguridad Física	Estado Actual	Problemas Detectados	Medidas Propuestas	Coste Estimado (€)	Prioridad
Cerradura / Sistema biométrico	Cerradura estándar	Sin registro de accesos ni restricción individual	Instalar control biométrico con tarjetas identificativas	1200	Alta
Registro de accesos	No implementado	No hay trazabilidad de quién entra/sale	Incorporar registro automático vinculado al sistema de acceso	500	Alta
Sistema antiincendios	Extintor manual	Falta de rociadores o sistema automático	Instalar sistema de detección y extinción automática (gas limpio)	2500	Alta
Detección de humos	Detector básico doméstico	No conectado a sistema de alarma	Sustituir por detector profesional conectado a alarma	300	Media
Control ambiental (temperatura)	Aire acondicionado estándar	No hay monitorización continua	Incorporar sensores de temperatura con alertas automáticas	400	Media
Control de humedad	No existente	Riesgo de condensación y fallos eléctricos	Instalar sensor de humedad y deshumidificador	300	Media
SAI / UPS	UPS básico de 600VA	Capacidad insuficiente para servidores críticos	Adquirir UPS de mayor capacidad y redundancia (mínimo 1500VA)	800	Alta
Sistema de refrigeración	Aire acondicionado convencional	Riesgo de sobrecalentamiento si falla	Instalar equipo redundante o monitorización IoT	1000	Alta
OFICINAS					
Política de escritorio limpio	No implementada formalmente	Documentos y dispositivos quedan visibles	Implementar política de “escritorio limpio” obligatoria	0	Media
Destructoras de papel	1 unidad común	Insuficiente para toda la plantilla	Incorporar 2 destructoras adicionales por departamento	250	Media
Armarios cerrados	Algunos con llave, otros abiertos	Información sensible accesible	Asignar armarios cerrados a cada área y control de llaves	400	Media
Control de dispositivos USB	No controlado	Riesgo de fuga o malware	Bloquear puertos USB por políticas del sistema y registro de uso	0	Alta
OTROS					
Cableado protegido	Expuesto en zonas de paso	Riesgo de desconexión o manipulación	Canalizar y proteger el cableado con tubos y canaletas	300	Media
Generador eléctrico backup	No disponible	Corte eléctrico detendría servidores y servicios críticos	Adquirir generador o contrato con proveedor de energía UPS	2000	Alta

ANÁLISIS Y PROTECCIÓN DE ACTIVOS DE
INFORMACIÓN

CETI

Elemento de Seguridad Física	Estado Actual	Problemas Detectados	Medidas Propuestas	Coste Estimado (€)	Prioridad
			Total:	16450	

Tarea 2.2: Plan de Seguridad Física

Diseña un plan de mejora de seguridad física que incluya:

PLAN DE SEGURIDAD FÍSICA

Empresa: TechSolutions Canarias S.L.

Versión: 1.0

Fecha: 16/10/2025

Responsable: Juan Carlos Francisco Mesa

1. MEDIDAS PERIMETRALES

1.1 Control de Acceso Físico

Situación actual:

Acceso mediante cerradura convencional y llaves físicas, sin control de registros ni autenticación individual.

Medida propuesta:

Instalación de sistema de control de acceso electrónico con tarjetas RFID o PIN, vinculado a registro automático de entradas/salidas.

Justificación:

Permite limitar y auditar accesos, evitar duplicado de llaves y mejorar la trazabilidad de movimientos dentro de la oficina.

Coste estimado: €1.500

Plazo de implementación: 1 mes

1.2 Zonificación de Áreas

Zonas identificadas:

- ✓ **Zona Pública:** Recepción y sala de reuniones con externos
- ✓ **Zona Restringida:** Oficinas de desarrollo, diseño y administración
- ✓ **Zona Crítica:** Sala de servidores (CPD)

Controles de acceso por zona:

Zona	Control de acceso	Medios Autorizados	Registro
Pública	Acceso libre con recepción presente	Visitantes, personal autorizado	No
Restringida	Tarjeta RFID / PIN	Empleados	Si
Crítica	Cerradura biométrica + tarjeta RFID	Admin. sistemas y gerente	Si

2. PROTECCIÓN SALA DE SERVIDORES

2.1 Acceso y Control

Tipo de cerradura propuesto:

Electrónica con lector biométrico (huella o reconocimiento facial).

Sistema de autenticación:

Tarjeta RFID + huella digital (doble factor).

Registro de accesos:

Automático mediante software vinculado al sistema de control.

Personal autorizado:

Administrador de sistemas, gerente y personal técnico específico.

2.2 Protección Ambiental

Control de temperatura:

Rango óptimo: 20°C – 24°C

Sistema de climatización:

Aire acondicionado profesional de precisión, con control IoT.

Alarmas:

Alertas automáticas vía correo/SMS ante sobrecalentamiento.

Control de humedad:

Rango óptimo: 45% – 55%

Sistema de deshumidificación:

Deshumidificador eléctrico con sensor digital.

Sensores:

Termo-higrómetros conectados a red local.

Sistema antiincendios:

- **Tipo de extinción:** Gas limpio (FM-200 o Novec 1230).
- **Detectores de humo:** Sensores ópticos conectados al sistema de alarma central.
- **Señalización:** Señales de emergencia fotoluminiscentes y plan de evacuación visible.

2.3 Suministro Eléctrico

SAI / UPS:

Potencia necesaria:

1,5 KVA

Autonomía:

20–30 minutos

Modelo propuesto:

APC Smart-UPS 1500VA o equivalente

Coste:

€800

Generador backup:

Necesario: Sí

Tipo de combustible: Gasolina (portátil)

Potencia: 2 KVA

Coste: €2.000

3. POLÍTICA DE ESCRITORIO LIMPIO Y GESTIÓN DE SOPORTES

3.1 Normas para Empleados

Al finalizar la jornada:

- ✓ Apagar o bloquear el equipo.
- ✓ Guardar documentos en armarios cerrados.
- ✓ Retirar notas adhesivas con contraseñas o datos sensibles.
- ✓ Desconectar dispositivos USB o externos.

Gestión de documentos:

- ✓ Clasificar documentos según sensibilidad.
- ✓ Destruir documentación confidencial.
- ✓ No dejar impresiones en impresoras compartidas.

Control de visitantes:

- ✓ Acompañamiento obligatorio en áreas restringidas.
- ✓ Prohibido hacer fotos o grabaciones.
- ✓ Registro de entrada y salida en recepción.

3.2 Procedimiento de Eliminación Segura

Documentos en papel:

- ✓ Uso de destructoras de corte cruzado (DIN P-4 o superior).
- ✓ Contenedores cerrados para acumular papel hasta destrucción.
- ✓ Solicitud de certificado de destrucción para documentos contables o legales.

Soportes digitales:

- ✓ Borrado seguro con estándares DoD 5220.22-M o software de sobreescritura múltiple.
- ✓ Destrucción física (triturado) para discos duros y USB en desuso.
- ✓ Registro interno de dispositivos eliminados.

3.3 Control de Dispositivos Extraíbles

Política USB:

- ✓ Solo dispositivos corporativos autorizados.
- ✓ Cifrado obligatorio (BitLocker, VeraCrypt).
- ✓ Registro de dispositivos asignados a usuarios.
- ✓ Implementar DLP (Data Loss Prevention) en endpoints para controlar transferencias de datos.

4. PRESUPUESTO CONSOLIDADO

Medida	Descripción	Coste (€)	Plazo	Prioridad
Control de acceso electrónico (tarjeta/PIN)	Control perimetral del edificio	1500	1 mes	Alta
Cerradura biométrica sala servidores	Acceso restringido con registro	1200	1 mes	Alta
Sistema de videovigilancia IP	Cámaras exteriores con grabación 24/7	2000	2 meses	Alta
Sistema antiincendios (gas limpio)	Protección automatizada de la sala CPD	2500	3 meses	Alta
UPS de 1.5 KVA	Respaldo eléctrico para servidores	800	1 mes	Alta
Generador eléctrico 2 KVA	Backup energético prolongado	2000	3 meses	Media
Sensores de temperatura y humedad	Control ambiental y alarmas IoT	700	1 mes	Media
Política de escritorio limpio + formación	Capacitación y cartelería	300	1 mes	Media
Destructoras y contenedores seguros	Eliminación segura de documentos	250	1 mes	Media
Canalización de cableado	Protección física del cableado	300	2 meses	Baja

Prioridades (coste/beneficio):

1. Alta: Control de acceso, cerradura biométrica, videovigilancia, antiincendios, UPS.
2. Media: Generador, sensores ambientales, políticas de escritorio limpio.
3. Baja: Mejoras estéticas o de cableado no críticas.

FASE 3: MEDIDAS DE SEGURIDAD LÓGICA

Tarea 3.1: Hardening de Sistemas

Para CADA uno de los siguientes sistemas de TechSolutions, propón medidas concretas de hardening:

a) Estaciones de trabajo de los desarrolladores (Windows 10/11):

Lista al menos 8 medidas de hardening específicas
Justifica cada medida (¿qué vulnerabilidad mitiga?)

b) Servidores Linux (web y base de datos):

Lista al menos 10 medidas de hardening específicas
Incluye configuraciones a nivel de: SO, servicios, red, usuarios

c) Dispositivos de red (switches, routers, WiFi):

Lista al menos 6 medidas de seguridad para la red
Incluye segmentación, filtrado, monitorización

HARDENING DE SISTEMAS

Empresa: TechSolutions Canarias S.L.

Fecha: 16/10/2025

Responsable: Juan Carlos Francisco Mesa

A) ESTACIONES DE TRABAJO WINDOWS (Windows 10/11)

#	Medida de Hardening	Descripción	Vulnerabilidad que Mitiga	Herramienta/Método	Prioridad
1	Desactivar SMBv1	Deshabilitar protocolo antiguo e inseguro	Exploits tipo WannaCry, EternalBlue	PowerShell: Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol	Alta
2	Activar BitLocker	Cifrar disco duro completo	Robo o pérdida de dispositivos	Configuración de BitLocker con TPM	Alta
3	Aplicar políticas de contraseñas seguras	Requerir longitud mínima, complejidad y caducidad	Acceso no autorizado por contraseñas débiles	Directiva de grupo (GPO)	Alta

#	Medida de Hardening	Descripción	Vulnerabilidad que Mitiga	Herramienta/Método	Prioridad
4	Restringir ejecución de macros en Office	Bloquear macros no firmadas	Malware por macros (phishing)	Configuración GPO o Office Trust Center	Media
5	Activar firewall de Windows y revisar reglas	Limitar tráfico no autorizado	Acceso remoto no autorizado	wf.msc o PowerShell	Alta
6	Desactivar autorun/autoplay	Evitar ejecución automática de malware en USB	Propagación de virus por medios extraíbles	GPO: "Turn off Autoplay"	Media
7	Mantener sistema y software actualizados	Aplicar actualizaciones automáticas y forzadas	Vulnerabilidades conocidas (CVE)	Windows Update + WSUS	Alta
8	Activar Windows Defender con protección en tiempo real	Antimalware integrado	Ransomware y troyanos	GPO o Endpoint Security	Alta

B) SERVIDORES LINUX

B.1 Nivel Sistema Operativo

#	Medida de Hardening	Comando/Configuración	Vulnerabilidad que Mitiga	Prioridad
1	Actualizar kernel y paquetes regularmente	apt update && apt upgrade	Vulnerabilidades conocidas (CVEs)	Alta
2	Desactivar servicios innecesarios	systemctl disable servicio	Reducción de superficie de ataque	Alta
3	Configurar logs centralizados	/etc/rsyslog.conf y logrotate	Pérdida de trazabilidad y detección de intrusiones	Media
4	Implementar SELinux/AppArmor	setenforce 1 o aa-enforce	Escalada de privilegios	Alta
5	Configurar banners legales	/etc/issue y /etc/motd	Disuasión y trazabilidad legal	Baja

B.2 Nivel Servicios

#	Servicio	Medida de Hardening	Configuración	Prioridad
1	SSH	Deshabilitar acceso root y cambiar puerto por defecto	/etc/ssh/sshd_config → PermitRootLogin no, Port 2222	Alta

#	Servicio	Medida de Hardening	Configuración	Prioridad
2	SSH	Autenticación con claves públicas y sin contraseñas	PasswordAuthentication no + claves RSA/ECDSA	Alta
3	Apache/Nginx	Desactivar listado de directorios y banners	Options -Indexes, ServerTokens Prod	Media
4	Apache/Nginx	Habilitar HTTPS con TLS 1.2/1.3	Configurar certificado Let's Encrypt	Alta
5	MySQL	Configurar acceso remoto restringido	bind-address = 127.0.0.1	Alta
6	MySQL	Establecer contraseñas seguras y privilegios mínimos	mysql_secure_installation	Alta

B.3 Nivel Red

#	Medida	Descripción	Configuración	Prioridad
1	Configurar firewall UFW/IPTables	Limitar puertos abiertos	ufw allow ssh, ufw deny all	Alta
2	Deshabilitar ICMP (ping) externo	Ocultar presencia del servidor	iptables -A INPUT -p icmp --icmp-type echo-request -j DROP	Media
3	Activar Fail2Ban	Bloquear IPs con intentos fallidos	/etc/fail2ban/jail.conf	Alta

B.4 Nivel Usuarios y Permisos

#	Medida	Descripción	Comando	Prioridad
1	Usar sudoers con privilegios mínimos	Asignar roles específicos	visudo → usuarios limitados	Alta
2	Auditoría de cuentas inactivas	Eliminar cuentas no utilizadas	lastlog, userdel	Media
3	Permisos correctos en ficheros críticos	Restringir acceso a /etc/passwd y /etc/shadow	chmod 600 /etc/shadow	Alta
4	Cifrado de backups	Usar gpg o openssl en copias de seguridad	gpg -c backup.tar.gz	Alta

C) DISPOSITIVOS DE RED (Switches, Routers, WiFi)

#	Dispositivo	Medida de Seguridad	Justificación	Configuración	Prioridad
1	Router	Cambiar credenciales por defecto	Evita accesos no autorizados	Panel admin / CLI	Alta
2	Router	Deshabilitar administración remota	Limita exposición al exterior	CLI o interfaz web	Alta
3	Switch	Activar VLANs y segmentar tráfico	Reduce propagación lateral de ataques	Configuración VLANs	Alta
4	WiFi AP	Configurar WPA3 y SSID oculto	Evita intrusiones por fuerza bruta	Panel WiFi	Alta
5	Firewall	Filtrar puertos y limitar tráfico saliente	Control de conexiones no deseadas	Reglas firewall	Alta
6	Todos	Actualizar firmware y registrar logs	Corrige vulnerabilidades de fabricante	Portal del fabricante	Media

Segmentación de Red Propuesta (Esquema VLANs)

VLAN	Descripción	Tipo de Dispositivos	Nivel de Acceso
VLAN 10	Gestión	Switches, routers, servidor de monitorización	Administradores
VLAN 20	Servidores	Web, DB, NAS	Restringido
VLAN 30	Usuarios	Estaciones de trabajo, portátiles	Limitado
VLAN 40	WiFi Invitados	Dispositivos visitantes	Internet only
VLAN 50	IoT / Seguridad	Cámaras IP, sensores	Aislado

Tarea 3.2: Gestión de Accesos e Identidades

Diseña un sistema de control de acceso para TechSolutions:

GESTIÓN DE ACCESOS E IDENTIDADES

Empresa: TechSolutions Canarias S.L.

Versión: 1.0

Fecha: 16/10/2025

1. POLÍTICA DE CONTRASEÑAS

1.1 Requisitos de Complejidad

Longitud mínima:

12 caracteres

Composición obligatoria:

- ✓ Mayúsculas (A-Z)
- ✓ Minúsculas (a-z)
- ✓ Números (0-9)
- ✓ Caracteres especiales (!@#\$%...)

Prohibiciones:

- ✓ Palabras del diccionario
- ✓ Datos personales (nombre, fecha de nacimiento, usuario...)
- ✓ Secuencias predecibles (123456, qwerty, password...)
- ✓ Reutilización de las últimas 5 contraseñas

1.2 Caducidad y Rotación

Caducidad:

Cada 90 días

Aviso previo:

10 días antes de vencimiento

Gracia tras caducidad:

5 días

Cambio forzoso:

Sí, al primer inicio de sesión

1.3 Almacenamiento Seguro

Herramienta propuesta:

Bitwarden Enterprise (o similar)

Justificación:

Permite la gestión centralizada y cifrada de contraseñas, con control de acceso por roles y auditoría.

Características:

- ✓ Cifrado: AES-256 end-to-end
- ✓ Autenticación: Master Password + MFA
- ✓ Compartición segura: Sí
- ✓ Auditoría: Sí (logs de acceso y cambios)
- ✓ Coste: €3 / usuario / mes

2. AUTENTICACIÓN MULTIFACTOR (MFA)

2.1 Sistemas Críticos que Requieren MFA

Sistema/Servicio	Justificación	Método MFA	Usuarios Afectados
VPN corporativa	Acceso remoto a red interna	App autenticadora	Todos los empleados con teletrabajo
Servidor BBDD (producción)	Contiene datos sensibles de clientes	Hardware token	Administrador de sistemas
Email corporativo (Microsoft 365 / Google Workspace)	Principal vector de phishing	App autenticadora	Todos los usuarios
Panel de administración de GitLab	Control de código fuente y despliegues	App autenticadora	Desarrolladores líderes y sysadmin
Panel NAS/Backup	Acceso a copias de seguridad	Hardware token	Administrador de sistemas

2.2 Método MFA Propuesto

- ☐ SMS
- ☒ App autenticadora (Authy / Microsoft Authenticator / Google Authenticator)
- ☐ Hardware token
- ☐ Biometría

Selección:

App autenticadora

Justificación:

Bajo coste, fácil integración con la mayoría de servicios, menor vulnerabilidad que el SMS.

Coste estimado:

€0 /usuario (uso de app gratuita autenticadora)

3. GESTIÓN DE USUARIOS

3.1 Proceso de Alta de Empleado

Paso	Acción	Responsable	Plazo
1	Solicitud formal de alta	RRHH	Día -5
2	Creación cuenta de usuario (AD/LDAP + email)	IT	Día -3
3	Asignación de roles y permisos	Supervisor + IT	Día -2
4	Generación de credenciales temporales	IT	Día -1
5	Entrega de equipo y credenciales seguras	IT	Día 1
6	Formación en políticas de seguridad y uso de MFA	RRHH / Seguridad	Semana 1
7	Verificación de accesos y logs iniciales	IT	Semana 2

3.2 Proceso de Baja de Empleado

Paso	Acción	Responsable	Plazo
1	Notificación de baja	RRHH	Día de notificación
2	Revocación accesos VPN y nube	IT	Último día laboral
3	Desactivación cuenta usuario (AD/LDAP, email, repositorios)	IT	Último día laboral
4	Recogida de equipos y dispositivos (portátil, móvil, token)	IT	Último día laboral
5	Cambio de contraseñas compartidas (repos, NAS, backups)	IT	Día +1
6	Revisión accesos a servicios externos (proveedores, CRM)	IT	Día +2
7	Eliminación definitiva de cuenta	IT	Día +90

Checklist baja empleado:

- ✓ Desactivar cuenta Active Directory / LDAP
- ✓ Revocar certificados digitales y claves SSH
- ✓ Eliminar acceso VPN
- ✓ Recoger portátil, móvil y tokens
- ✓ Cambiar contraseñas de cuentas compartidas
- ✓ Revocar acceso a servicios cloud (GitHub, M365, etc.)
- ✓ Eliminar de grupos de correo y equipos colaborativos
- ✓ Transferir propiedad de archivos a supervisor

3.3 Revisión Periódica de Permisos

Frecuencia:

Trimestral

Responsable:

Administrador de Sistemas + Gerente

Proceso:

- Generar listado actualizado de usuarios y roles.
- Validar accesos con cada jefe de departamento.
- Identificar cuentas inactivas o permisos excesivos.
- Revocar accesos innecesarios.
- Documentar los cambios realizados y firmar control de revisión.

4. CONTROL DE ACCESO BASADO EN ROLES (RBAC)

ROL 1: DESARROLLADOR

Descripción:

Personal de desarrollo de software web y móvil.

Sistemas accesibles:

- ✓ Repositorio de código (GitLab)
- ✓ Servidor de desarrollo
- ✓ Base de datos de pruebas
- ✓ Herramientas de desarrollo (VS Code, Docker, etc.)

Permisos:

- ✓ Lectura
- ✓ Escritura
- ✓ Ejecución

Restricciones:

- x Acceso a servidor de producción
- x Acceso a BBDD de clientes
- x Modificación de backups

ROL 2: ADMINISTRADOR DE SISTEMAS

Descripción:

Encargado de la infraestructura, servidores y red.

Sistemas accesibles:

- ✓ Servidores Linux (web, BBDD, backup)
- ✓ Paneles de red (routers, NAS, UPS)
- ✓ Consolas cloud y VPN

Permisos:

- ✓ Lectura
- ✓ Escritura
- ✓ Ejecución (root)

Restricciones:

- x No modificar código sin autorización
- x Acceso limitado a datos personales (solo técnicos)

ROL 3: COMERCIAL

Descripción:

Equipo de ventas y atención a clientes.

Sistemas accesibles:

- ✓ CRM / Base de datos clientes
- ✓ Correo corporativo
- ✓ Documentos de presupuestos

Permisos:

- ✓ Lectura
- ✓ Escritura: (solo CRM y documentos propios)
- x Ejecución

Restricciones:

- x Acceso a código fuente o infraestructura técnica
- x Acceso a BBDD internas de desarrollo

ROL 4: DISEÑADOR

Descripción:

Personal de diseño gráfico y UX/UI.

Sistemas accesibles:

- ✓ Servidor de archivos (recursos gráficos)
- ✓ Herramientas de diseño (Figma, Adobe CC)
- ✓ Repositorio compartido de medios

Permisos:

- ✓ Lectura
- ✓ Escritura (archivos propios)
- ✗ Ejecución

Restricciones:

- ✗ Acceso a servidores o bases de datos
- ✗ Modificación de documentación técnica

ROL 5: GERENTE

Descripción:

Dirección general y control administrativo.

Sistemas accesibles:

- ✓ Sistema de facturación / contabilidad
- ✓ Email corporativo y gestión de usuarios
- ✓ Dashboard de informes (ventas, proyectos)

Permisos:

- ✓ Lectura
- ✓ Escritura (solo administrativos)
- ✗ Ejecución

Restricciones:

- ✗ Acceso técnico directo a servidores o BBDD
- ✗ No modificar configuraciones de seguridad

Resumen general:

- MFA obligatorio para VPN, correo y sistemas críticos.
- Política de contraseñas robusta y renovable cada 90 días.
- RBAC claro y documentado, con revisión trimestral.
- Uso de gestor de contraseñas cifrado (Bitwarden Enterprise).

Tarea 3.3: Protección de Endpoints y Datos

Propón una estrategia completa de protección:

PROTECCIÓN DE ENDPOINTS Y DATOS

Empresa: TechSolutions Canarias S.L.

Fecha: 16/10/2025

Responsable: Administrador de Sistemas / CISO

1. ANTIVIRUS / EDR

1.1 Soluciones Evaluadas

SOLUCIÓN 1

Nombre:

Microsoft Defender for Business (M365)

Tipo:

EDR (Endpoint Detection & Response)

Características principales:

- Detección basada en firmas
- Detección de comportamiento y anomalías
- Sandboxing de archivos sospechosos en la nube
- Respuesta automática ante amenazas
- Integración con SIEM (Microsoft Sentinel, Splunk, etc.)
- Gestión centralizada desde portal M365

Plataformas soportadas:

Windows / macOS / Android / iOS

Coste:

€3,20 / dispositivo / mes ($\approx$ €38,40 / año)

Ventajas:

- Integración nativa con Windows 10/11
- Control unificado en la consola M365
- Excelente relación coste-beneficio
- MFA y DLP integrados en el ecosistema Microsoft

Desventajas:

- Protección limitada en Linux
- Requiere suscripción M365 Business Premium o superior

SOLUCIÓN 2

Nombre:

CrowdStrike Falcon Prevent + Insight

Tipo:

EDR / XDR

Características principales:

- Machine Learning sin firmas
- Análisis en la nube con IA
- Detección avanzada de ransomware
- Contención remota de endpoints
- Integración con SIEM externos (Splunk, SentinelOne)
- Panel de gestión web centralizado

Plataformas soportadas:

Windows / Linux / macOS / Android / iOS

Coste:

€8,50 / dispositivo / mes (≈ €102 / año)

Ventajas:

- EDR de clase empresarial, muy robusto
- Excelente protección Linux y servidores
- Baja carga en el sistema (cloud-first)

Desventajas:

Precio más alto

Requiere formación para su consola avanzada

1.2 Recomendación Final

Solución seleccionada: Microsoft Defender for Business (M365)

Justificación:

Equilibrio óptimo entre coste, integración y efectividad para el tamaño y entorno mixto de TechSolutions. Defender cubre antivirus, firewall, control de aplicaciones y EDR con administración centralizada. CrowdStrike podría añadirse a futuro en fase de expansión.

Coste total estimado:

20 dispositivos × €38,40 = €768 / año

2. DATA LOSS PREVENTION (DLP)

2.1 Escenarios de Fuga de Información

ESCENARIO 1

Descripción:

Empleado envía código fuente por email personal

Tipo de dato:

Propiedad intelectual

Canal:

Email

Riesgo:

Alto

Medida DLP propuesta:

- Bloqueo automático de envío de archivos con extensiones .py, .php, .js a dominios externos
- Escaneo de adjuntos mediante Microsoft Purview DLP
- Alerta al responsable de seguridad
- Autorización previa para envíos externos cifrados (S/MIME)

ESCENARIO 2

Descripción:

Copia de base de datos de clientes a USB personal

Tipo de dato:

Datos personales (RGPD)

Canal:

Dispositivos extraíbles

Riesgo:

Alto

Medida DLP propuesta:

- Bloqueo de puertos USB para lectura/escritura en equipos no corporativos
- Permitir solo dispositivos cifrados (BitLocker To Go)
- Registro y auditoría de uso de soportes externos
- Alerta y reporte automático en consola EDR

ESCENARIO 3

Descripción:

Captura de pantalla con datos sensibles compartida en chat corporativo

Tipo de dato:

Información financiera / clientes

Canal:

Mensajería interna (Teams / Slack)

Riesgo:

Medio

Medida DLP propuesta:

- Política DLP en Teams/Slack: detección de números de cuenta, CIF o DNI
- Bloqueo automático o advertencia antes de envío
- Formación y concienciación en RGPD y confidencialidad
- Auditoría de logs de conversación sensible

3. COPIAS DE SEGURIDAD

3.1 Estrategia 3-2-1

3 copias de los datos:

1. Copia primaria: Datos en producción (servidores y estaciones)
2. Copia secundaria 1: NAS local en sala de servidores
3. Copia secundaria 2: Backup cifrado en la nube (AWS S3 / Wasabi / Azure Blob)

2 tipos de medios:

1. Medio 1: Disco NAS (RAID 5)
2. Medio 2: Cloud Storage cifrado

1 copia offsite:

1. Ubicación: Nube (AWS S3 región Irlanda)
2. Método: Sincronización automatizada mediante rclone + cron job diario

3.2 Política de Backup Detallada

Tipo de Dato	Frecuencia	Retención	Método	Ubicación	Cifrado	Responsable
BBDD clientes	Diaria incremental / Semanal completa	30 días incrementales / 12 meses completas	mysqldump + rclone	NAS local + AWS S3	AES-256	Admin Sistemas
Código fuente	Diario	6 meses	GitLab backup automático	Cloud Git + NAS	AES-256	DevOps
Documentos corporativos	Semanal	1 año	Copia sincronizada (Syncthing)	NAS + Cloud	AES-256	IT
Configuraciones servidores	Cada cambio / Semanal	6 meses	Script Ansible Backup	NAS	AES-256	Sysadmin
Emails corporativos	Diario	1 año	Backup M365 / Google Vault	Cloud	AES-256	Admin IT

3.3 Pruebas de Restauración

Frecuencia:

Trimestral

Alcance:

Restauración completa de un servidor y parcial de BBDD

Responsable:

Administrador de Sistemas

Documentación:

Registro detallado de cada prueba, tiempos de restauración y validación de integridad de datos

3.4 Tiempo de Retención

Tipo de Información	Retención	Justificación Legal
Datos fiscales	7 años	Ley General Tributaria
Datos laborales	4 años	Estatuto de los Trabajadores
Datos de clientes (RGPD)	Hasta 2 años tras finalización de relación contractual	RGPD Art.5
Logs de acceso	1 año	Buenas prácticas ISO 27001 / ENS

4. CIFRADO

4.1 Cifrado en Reposo

Tipo de Dato	Ubicación	Método de Cifrado	Herramienta	Gestión de Claves
BBDD clientes	Servidor MySQL	TDE (Transparent Data Encryption)	MySQL Enterprise / MariaDB	Custodia IT
Backups	NAS + Cloud	AES-256	VeraCrypt / rclone crypt	Claves en cofre Bitwarden
Discos portátiles	Equipos móviles	Cifrado completo disco	BitLocker / LUKS	Claves en AD + Bitwarden
Archivos sensibles	Servidor de archivos	AES-256 por carpeta	7-Zip + política DLP	Claves rotadas trimestralmente

4.2 Cifrado en Tránsito

Comunicación	Protocolo Actual	Protocolo Seguro	Puerto	Certificado
Web → Servidor	HTTP	HTTPS (TLS 1.3)	443	Let's Encrypt
Email	SMTP	SMTPS / STARTTLS	587 / 465	Certificado M365
FTP	FTP	SFTP / FTPS	22 / 990	Certificado interno
BBDD	MySQL sin cifrar	MySQL sobre SSL	3306	Cert BBDD
Acceso remoto	—	VPN (OpenVPN/IPSec)	1194 / 500	Certificado CA interna

4.3 Herramientas y Protocolos Específicos

Para archivos:

- Herramienta: VeraCrypt / 7-Zip con AES-256
- Algoritmo: AES-256-CBC
- Intercambio de claves: PGP (GnuPG)

Para email:

- Protocolo: S/MIME
- Herramienta: Integración Outlook / Thunderbird

Para VPN:

- Protocolo: OpenVPN
- Cifrado: AES-256-GCM
- Autenticación: Certificados + MFA (app autenticadora)

Tarea 3.4: Monitorización y Gestión de Vulnerabilidades

Completa el plan de monitorización:

MONITORIZACIÓN Y GESTIÓN DE VULNERABILIDADES

Empresa: TechSolutions Canarias S.L.

Fecha: 16/10/2025

Responsable: Administrador de Sistemas (Carlos Mendoza)

1. SIEM / MONITORIZACIÓN

1.1 Eventos a Monitorizar

Categoría	Evento Específico	Origen	Criticidad	Acción
Autenticación	Inicio sesión fallido (>5 intentos)	Servidores, AD	Alta	Alerta + bloqueo de cuenta
	Inicio sesión fuera de horario	Servidores	Media	Alerta
	Cambio de contraseña	AD	Baja	Registro
Accesos	Acceso denegado a recurso	Servidor de archivos	Media	Registro
	Escalada de privilegios	Servidores	Alta	Alerta inmediata
	Acceso a archivos sensibles	Servidores	Alta	Alerta
Red	Tráfico hacia IPs maliciosas conocidas	Firewall	Alta	Bloqueo + Alerta
	Escaneo de puertos	IDS/Wazuh	Alta	Alerta
	Tráfico anómalo (volumen o destino)	Firewall	Media	Alerta
Sistema	Instalación de software no autorizado	Endpoints	Media	Alerta
	Cambio de configuración del firewall	Servidores	Alta	Alerta inmediata
	Servicio crítico detenido (Apache, MySQL)	Servidores	Alta	Alerta + reinicio automático
Malware	Detección de malware	EDR	Alta	Cuarentena + alerta
	Ransomware (múltiples archivos cifrados)	EDR/Wazuh	Crítica	Aislamiento + alerta inmediata

1.2 Solución SIEM Propuesta

Solución	Tipo	Características	Coste	Ventajas	Desventajas
Splunk	Comercial	Alta capacidad de correlación, dashboards avanzados	€€€	Muy potente, soporte comercial	Coste elevado
ELK Stack (Elasticsearch + Logstash + Kibana)	Open Source	Centralización de logs, dashboards personalizables	Gratis*	Flexible y visual	Configuración compleja
Wazuh (seleccionada)	Open Source	SIEM + IDS + monitorización endpoints + alertas automáticas	Gratis*	Fácil integración, dashboards en Kibana, agentes multiplataforma	Requiere tuning inicial

Selección: Wazuh SIEM (Open Source)

Justificación: Solución gratuita, moderna, escalable y compatible con Linux/Windows; ideal para pymes. Permite correlación de eventos, detección de malware, integraciones con EDR y alertas en tiempo real.

Coste: 0 € (solo infraestructura y mantenimiento interno).

1.3 Alertas Críticas Configuradas

ALERTA	Condición	Severidad	Acción Automática	Notificación
1. Intento de intrusión	>10 intentos de login fallidos en <5 min desde misma IP	Crítica	Bloqueo IP + bloqueo cuenta	Email a seguridad@techsolutions.com + ticket
2. Detección de ransomware	Actividad de cifrado masivo en disco	Crítica	Aislar endpoint + detener proceso + alerta	Email + SMS a Admin
3. Tráfico hacia IP maliciosa	Conexión saliente a dominio en lista negra	Alta	Bloqueo automático firewall	Email + alerta SIEM
4. Escalada de privilegios	Usuario normal obtiene root/admin	Alta	Notificación inmediata	Email + dashboard
5. Servicio crítico caído	Apache/MySQL detenido >2 min	Alta	Intentar reinicio + alerta	Email + dashboard

2. GESTIÓN DE VULNERABILIDADES

2.1 Procedimiento de Gestión de Parches

Fase	Acción	Responsable	Período	SLA
1. Identificación	Revisar boletines (Microsoft, Debian, Apache, etc.)	Admin Sistemas	Semanal	Cada martes
2. Evaluación	Analizar criticidad y aplicabilidad	Admin Sistemas	-	24 h tras parche crítico
3. Pruebas	Test en entorno de staging	Admin Sistemas	-	48 h
4. Aprobación	Validar despliegue	Gerente TI	-	24 h
5. Despliegue	Aplicar parches en producción	Admin Sistemas	-	7 días (críticos) / 30 días (otros)
6. Verificación	Comprobar instalación correcta	Admin Sistemas	-	24 h post-despliegue

Clasificación:

Críticos: Vulnerabilidades explotadas activamente → aplicar < 7 días

Importantes: Gravedad alta → < 30 días

Moderados: Vulnerabilidades menores → < 90 días

2.2 Escaneo de Vulnerabilidades

Frecuencia de escaneo:

- Servidores críticos → semanal
- Otros servidores → quincenal
- Estaciones de trabajo → mensual
- Dispositivos de red → mensual
- Aplicaciones web → trimestral o tras cambios importantes

Herramienta	Tipo	Funcionalidad	Coste	Selección
Nessus	Comercial	Escaneo completo, CVSS, informes detallados	€	✗
OpenVAS (Greenbone)	Open Source	Escaneo red y SO, CVE actualizado	Gratis	✓
Qualys	Cloud	Escaneo + compliance	€€	✗
OWASP ZAP	Open Source	Escaneo apps web	Gratis	✓
Nikto	Open Source	Escaneo web simple	Gratis	✗

Herramientas seleccionadas:

- OpenVAS (para red y sistemas)
- OWASP ZAP (para aplicaciones web internas y portales clientes)

3. RESPUESTA A INCIDENTES

3.1 Procedimiento Básico (5 Pasos)

PASO 1: PREPARACIÓN

- Responsables:
 - Coordinador incidentes: Gerente TI (Ana Suárez)
 - Equipo respuesta: Admin Sistemas + Consultor externo
- Recursos:
 - SIEM (Wazuh), EDR, copias de seguridad, manuales
 - Contactos: INCIBE, Policía Nacional (Grupo Cibercrimen)

PASO 2: DETECCIÓN Y ANÁLISIS

- Identificación del incidente (alerta, usuario afectado)
- Determinar alcance y severidad
- Clasificar tipo (malware, fuga, intrusión, DDoS, etc.)
- Responsable: Admin Sistemas
- Herramientas: SIEM, EDR, logs, Wireshark

PASO 3: CONTENCIÓN

- Corto plazo: aislar equipos comprometidos, revocar accesos
- Largo plazo: aplicar mitigaciones, firewall rules
- Responsable: Admin Sistemas / Gerente TI

PASO 4: ERRADICACIÓN Y RECUPERACIÓN

- Eliminar causa raíz (malware, exploit)
- Restaurar desde backup limpio
- Validar servicios y realizar monitoreo 72 h
- Responsable: Admin Sistemas
- Apoyo: Gerente TI, proveedor cloud

PASO 5: LECCIONES APRENDIDAS

- Reunión post-incidente en 72 h

- Documentar cronología, impacto, tiempos
- Mejoras en políticas o controles
- Responsable: Gerente TI

3.2 Matriz RACI (Responsabilidades)

Fase Incidente	Admin Sistemas	Gerente TI	Gerente General	Legal	RRHH
Detección	R, A	I	I	-	-
Análisis inicial	R, A	C, I	I	-	-
Contención	R, A	C, I	I	-	-
Comunicación interna	C	R, A	C, I	-	I
Comunicación externa	C	C	R, A	C	-
Erradicación	R, A	C, I	I	-	-
Recuperación	R, A	C, I	I	-	-
Investigación forense	R	A, I	C, I	C	-
Lecciones aprendidas	C, I	R, A	C, I	-	-

- **R** (Responsible o Responsable): Persona o rol que ejecuta la tarea o realiza la acción.
- **A** (Accountable llamado también Aprobador): Persona o rol responsable final del resultado y quien toma las decisiones.
- **C** (Consulted o Consultado): Persona o rol consultado durante el proceso, aporta información o asesoramiento.
- **I** (Informed o Informado): Persona o rol informado del progreso o de las decisiones tomadas, pero no participa directamente.